

Statement of Applicability (SoA) — ISO 27001:2022 — TechShop SAS

Version : 1.0
Date : Juin 2026
Auteur : Dorian Poncelet (Consultant GRC)
Validé par : Marie Laurent (DG) — Juin 2026
Statut : Validé
Référence norme : ISO/IEC 27001:2022 — Annex A (93 contrôles)

Mode de lecture

Champ	Valeurs possibles
Applicable	Oui / Non / Partiel
Statut	Implémenté / En cours / Planifié / N/A
Lié au risque	Référence(s) du registre des risques

Justification des exclusions (Non applicable)

Tout contrôle marqué **Non** doit être justifié. L'absence de justification est une non-conformité en audit ISO 27001. Les exclusions de TechShop SAS sont principalement liées à l'absence de certaines activités (pas de développement logiciel interne, pas de site physique de secours formel).

Taux de couverture

- **Implémenté** = contrôle en place et prouvable
- **En cours** = démarré, preuve partielle
- **Planifié** = décidé, pas encore démarré
- **N/A** = non applicable (contrôle exclu avec justification)

A.5 — Contrôles Organisationnels (37 contrôles)

ID	Contrôle	Applicable	Statut	Responsable	Preuve / Justification	Risque lié
A.5.1	Politiques de sécurité de l'information	Oui	En cours	DG + DSI	Politique de sécurité en rédaction (smsi/01-politique/)	R01–R15
A.5.2	Rôles et responsabilités en matière de sécurité	Oui	En cours	DG	Organigramme sécurité défini, fiches de poste à formaliser	R01–R15
A.5.3	Séparation des tâches	Partiel	En cours	DSI	Séparation admin/utilisateur Odoo en cours ; GW admin = 1 seul compte	R03, R05
A.5.4	Responsabilités de la direction	Oui	Implémenté	DG	Engagement direction formalisé dans la politique de sécurité	—
A.5.5	Relations avec les autorités	Oui	Planifié	DPO	Contact CNIL à documenter ; procédure notification 72h à formaliser	R02, R07
A.5.6	Relations avec des groupes d'intérêt spéciaux	Non	N/A	—	PME sans obligation de veille sectorielle formalisée à ce stade	—
A.5.7	Renseignement sur les menaces (Threat intelligence)	Partiel	Planifié	DSI	Abonnement CERT-FR à activer ; veille CVE WordPress manuelle	R01, R06
A.5.8	Sécurité de l'information dans la gestion de projet	Partiel	Planifié	DSI	Projets IT sans security by design formalisé ; checklist à créer	R02, R06
A.5.9	Inventaire des actifs	Oui	Implémenté	DSI	smsi/03-analyse-risques/inventaire-actifs.md (26 actifs)	R01–R15
A.5.10	Utilisation acceptable des actifs	Oui	En cours	DSI + RH	Charte informatique à valider par tous les employés	R09, R10

ID	Contrôle	Applicable	Statut	Responsable	Preuve / Justification	Risque lié
A.5.11	Restitution des actifs	Oui	Planifié	DRH	Procédure offboarding en cours de formalisation	R05
A.5.12	Classification de l'information	Oui	Implémenté	DPO + DSI	Grille de classification dans inventaire-actifs.md	R02, R07
A.5.13	Étiquetage de l'information	Partiel	Planifié	DSI	Classification documentée, étiquetage physique des supports à faire	R02
A.5.14	Transfert de l'information	Oui	En cours	DSI + DPO	Chiffrement TLS en place ; SCC AWS à documenter (R07)	R07
A.5.15	Contrôle d'accès	Oui	En cours	DSI	Politique d'accès définie ; implémentation partielle sur Odoo/GW	R03, R05, R12
A.5.16	Gestion des identités	Oui	En cours	DSI	Comptes nominatifs GW ; comptes génériques Odoo à supprimer	R03, R05
A.5.17	Informations d'authentification	Oui	En cours	DSI	Politique MDP définie ; MFA partiellement déployé (R03)	R03
A.5.18	Droits d'accès	Oui	En cours	DSI	Revue des droits en cours ; accès ex-employés à auditer	R05, R12
A.5.19	Sécurité de l'information dans les relations fournisseurs	Oui	En cours	DSI + Direction	Contrats Stripe/OVH/AWS en place ; DPA RGPD à compléter	R04, R07
A.5.20	Gestion de la sécurité dans les contrats fournisseurs	Oui	Planifié	Direction	Clauses sécurité à ajouter dans les nouveaux contrats	R04

ID	Contrôle	Applicable	Statut	Responsable	Preuve / Justification	Risque lié
A.5.21	Gestion de la sécurité dans la chaîne d'approvisionnement TIC	Oui	Planifié	DSI	Cartographie dépendances critiques (Stripe, Cloudflare, OVH)	R04
A.5.22	Surveillance et revue des services fournisseurs	Oui	Planifié	DSI	Revue annuelle SLA fournisseurs à planifier	R04, R08
A.5.23	Sécurité de l'information pour l'utilisation de services cloud	Oui	En cours	DSI	AWS, GW, HubSpot utilisés ; politique cloud à formaliser	R07, R11
A.5.24	Planification de la gestion des incidents de sécurité	Oui	En cours	DSI + DPO	Procédure incident en cours (poc/cnil/) ; à généraliser	R01, R02
A.5.25	Évaluation et décision sur les incidents	Oui	Planifié	DSI	Critères de gravité à formaliser (niveaux P1/P2/P3)	R01, R02
A.5.26	Réponse aux incidents de sécurité	Oui	En cours	DSI	Procédure de réponse basique ; playbooks à développer	R01, R02
A.5.27	Apprentissage des incidents de sécurité	Oui	Planifié	DSI	Post-mortem à formaliser après chaque incident P1/P2	R01
A.5.28	Collecte de preuves	Oui	Planifié	DSI	Procédure de préservation des logs à écrire	R01, R02
A.5.29	Sécurité de l'information pendant une perturbation	Oui	Planifié	DSI + DG	PRA/PCA à formaliser (RTO < 4h, RPO < 24h)	R01, R08
A.5.30	Préparation des TIC à la continuité d'activité	Oui	Planifié	DSI	Architecture de continuité à documenter	R08

ID	Contrôle	Applicable	Statut	Responsable	Preuve / Justification	Risque lié
A.5.31	Obligations légales, statutaires, réglementaires et contractuelles	Oui	En cours	DPO + Direction	RGPD, NIS2 en cours d'évaluation ; registre des traitements à jour	R07
A.5.32	Droits de propriété intellectuelle	Oui	Implémenté	Direction	Licences logicielles inventoriées ; WordPress GPL, Odoo LGPL	—
A.5.33	Protection des enregistrements	Oui	En cours	DSI + DPO	Politique de rétention à formaliser ; transferts hors UE à corriger	R07
A.5.34	Confidentialité et protection des données à caractère personnel	Oui	En cours	DPO	Registre des traitements en cours ; DPA à compléter	R02, R07
A.5.35	Revue indépendante de la sécurité de l'information	Oui	Planifié	DG	Audit interne annuel planifié ; audit externe à budgéter	—
A.5.36	Conformité aux politiques et normes de sécurité	Oui	En cours	DSI	Revue de conformité semestrielle à instaurer	—
A.5.37	Procédures d'exploitation documentées	Oui	En cours	DSI	Procédures OVH et AWS partiellement documentées	R08

Taux A.5 : Implémenté : 4 (11%) / En cours : 18 (49%) / Planifié : 13 (35%) / N/A : 1 (3%) / Non : 1 (3%)

A.6 — Contrôles relatifs aux personnes (8 contrôles)

ID	Contrôle	Applicable	Statut	Responsable	Preuve / Justification	Risque lié
A.6.1	Sélection (screening)	Oui	Partiel	DRH	Vérification références pratiquée ; procédure écrite manquante	R05

ID	Contrôle	Applicable	Statut	Responsable	Preuve / Justification	Risque lié
A.6.2	Termes et conditions d'emploi	Oui	En cours	DRH + Direction	Contrats de travail signés ; clause confidentialité à renforcer	R05, R12
A.6.3	Sensibilisation, éducation et formation à la sécurité	Oui	Planifié	DSI + RH	Aucune formation sécurité formelle à ce jour — GAP CRITIQUE	R10
A.6.4	Processus disciplinaire	Oui	Implémenté	DRH	Règlement intérieur existant avec sanctions	R05
A.6.5	Responsabilités après cessation ou modification du contrat	Oui	En cours	DRH + DSI	Offboarding informel ; checklist de révocation à formaliser	R05
A.6.6	Accords de confidentialité et de non-divulgaration	Oui	En cours	Direction	NDA signé pour les prestataires IT ; employés : à formaliser	R02, R12
A.6.7	Travail à distance	Oui	En cours	DSI	VPN WireGuard en place ; politique télétravail à écrire	R09, R13
A.6.8	Signalement des événements liés à la sécurité	Oui	Planifié	DSI	Canal de signalement à créer (email dédié ou outil)	R01, R02

Taux A.6 : Implémenté : 1 (13%) / En cours : 4 (50%) / Planifié : 2 (25%) / Partiel : 1 (13%)

A.7 — Contrôles physiques (14 contrôles)

ID	Contrôle	Applicable	Statut	Responsable	Preuve / Justification	Risque lié
A.7.1	Périmètres de sécurité physique	Partiel	En cours	Direction	Bureaux Toulouse sécurisés (badge) ; entrepôt Labège : contrôle à renforcer	—
A.7.2	Contrôles d'accès physiques	Oui	En cours	Direction	Badges nominatifs au siège ; registre visiteurs à mettre en place	—
A.7.3	Sécurisation des bureaux, salles et installations	Oui	Implémenté	Direction	Locaux fermés à clé, alarme intrusion en place	—
A.7.4	Surveillance physique	Partiel	Planifié	Direction	Caméras entrepôt ; bureau Toulouse sans surveillance vidéo	—
A.7.5	Protection contre les menaces physiques et environnementales	Oui	En cours	Direction	Détecteur incendie ; UPS sur serveur local ; plan évacuation affiché	R08
A.7.6	Travail dans les zones sécurisées	Oui	En cours	DSI + Direction	Politique clean desk à formaliser	—
A.7.7	Bureau propre et écran vide	Oui	Planifié	DSI + RH	Politique à rédiger et sensibilisation à faire	—
A.7.8	Emplacement et protection du matériel	Oui	Implémenté	DSI	Serveurs hébergés OVH (datacenter certifié ISO 27001)	R08
A.7.9	Sécurité des actifs hors site	Oui	En cours	DSI	Politique BYOD /équipement nomade à formaliser	R09

ID	Contrôle	Applicable	Statut	Responsable	Preuve / Justification	Risque lié
A.7.10	Supports de stockage	Oui	En cours	DSI	Politique de destruction des supports à écrire ; chiffrement laptops en cours	R02
A.7.11	Services généraux (alimentation, réseau)	Oui	Implémenté	DSI	Infrastructure OVH avec redondance électrique ; fibre secourue	R08
A.7.12	Sécurité du câblage	Non	N/A	—	Infrastructure principalement cloud/SaaS — câblage local non critique	—
A.7.13	Maintenance du matériel	Oui	En cours	DSI	Contrat maintenance OVH ; postes de travail : politique à formaliser	—
A.7.14	Mise au rebut et réutilisation sécurisée du matériel	Oui	Planifié	DSI	Procédure d'effacement certifié à créer (DBAN ou équivalent)	R02

Taux A.7 : Implémenté : 3 (21%) / En cours : 7 (50%) / Planifié : 3 (21%) / N/A : 1 (7%)

A.8 — Contrôles technologiques (34 contrôles)

ID	Contrôle	Applicable	Statut	Responsable	Preuve / Justification	Risque lié
A.8.1	Équipements utilisateurs	Oui	En cours	DSI	MDM non déployé ; politique utilisation postes à formaliser	R09, R10
A.8.2	Droits d'accès privilégiés	Oui	En cours	DSI	Comptes admin identifiés ; PAM (Privileged Access Management) à implémenter	R03, R05, R17

ID	Contrôle	Applicable	Statut	Responsable	Preuve / Justification	Risque lié
A.8.3	Restriction d'accès à l'information	Oui	En cours	DSI	RBAC Odoo en cours de reconfiguration	R05, R12
A.8.4	Accès au code source	Non	N/A	—	Pas de développement logiciel interne chez TechShop SAS	—
A.8.5	Authentification sécurisée	Oui	En cours	DSI	MFA déployé partiellement (DG uniquement) ; extension en cours	R03
A.8.6	Gestion de la capacité	Oui	En cours	DSI	Supervision Grafana/Prometheus en place ; alertes capacité à configurer	R08
A.8.7	Protection contre les maliciels	Oui	Planifié	DSI	Antivirus basique sur postes ; EDR à déployer sur serveurs OVH	R01, R10
A.8.8	Gestion des vulnérabilités techniques	Oui	En cours	DSI	WPScan mensuel (poc/wpscan) ; politique patch à formaliser	R06, R14, R15
A.8.9	Gestion de la configuration	Oui	En cours	DSI	Configurations OVH documentées partiellement ; IaC non utilisé	R13
A.8.10	Suppression de l'information	Oui	Planifié	DSI + DPO	Politique de purge données clients à créer (RGPD Art. 17)	R07
A.8.11	Masquage des données	Oui	Planifié	DSI + DPO	Pseudonymisation données clients en BDD à implémenter	R02
A.8.12	Prévention des fuites de données (DLP)	Partiel	Planifié	DSI	Cloudflare WAF couvre partiellement ; DLP complet non déployé	R02

ID	Contrôle	Applicable	Statut	Responsable	Preuve / Justification	Risque lié
A.8.13	Sauvegarde des informations	Oui	En cours	DSI	Backups AWS S3 en place ; Object Lock et tests à activer (R11)	R01, R11
A.8.14	Redondance des moyens de traitement	Oui	Planifié	DSI	Architecture mono-serveur OVH ; PRA à documenter	R08
A.8.15	Journalisation	Oui	En cours	DSI	Logs Grafana/Prometheus ; rétention et centralisation à améliorer	R01, R02
A.8.16	Activités de surveillance	Oui	En cours	DSI	Supervision Grafana en place ; alertes sécurité à configurer	R01
A.8.17	Synchronisation des horloges	Oui	Implémenté	DSI	NTP configuré sur serveurs OVH	—
A.8.18	Utilisation de programmes utilitaires privilégiés	Oui	En cours	DSI	Accès SSH root restreint au VPN ; sudo à auditer	R03
A.8.19	Installation de logiciels sur les systèmes en exploitation	Oui	En cours	DSI	Politique d'installation à formaliser ; whitelist applicative non déployée	R10
A.8.20	Sécurité des réseaux	Oui	En cours	DSI	Cloudflare + WireGuard VPN ; segmentation VLAN à compléter	R09, R13
A.8.21	Sécurité des services réseau	Oui	En cours	DSI	TLS 1.3 sur WooCommerce ; audit TLS à réaliser	R09
A.8.22	Filtrage du Web	Oui	En cours	DSI	Cloudflare WAF actif ; règles OWASP à activer en mode blocage	R02, R06, R14

ID	Contrôle	Applicable	Statut	Responsable	Preuve / Justification	Risque lié
A.8.23	Utilisation de la cryptographie	Oui	En cours	DSI	TLS en place ; chiffrement BDD et disques à compléter	R02
A.8.24	Politique de cryptographie	Oui	Planifié	DSI	Politique crypto formelle à rédiger (algorithmes, longueurs de clé)	R02
A.8.25	Cycle de vie du développement sécurisé	Non	N/A	—	Pas de développement logiciel interne ; applicable aux plugins WooCommerce tiers	—
A.8.26	Exigences de sécurité des applications	Partiel	Planifié	DSI	Exigences sécurité à définir pour les plugins WooCommerce achetés	R06
A.8.27	Principes d'ingénierie des systèmes sécurisés	Non	N/A	—	Pas de développement interne	—
A.8.28	Codage sécurisé	Non	N/A	—	Pas de développement interne — applicable aux thèmes/plugins sur mesure uniquement	R06
A.8.29	Tests de sécurité en développement et acceptation	Non	N/A	—	Pas de développement interne	—
A.8.30	Externalisation du développement	Non	N/A	—	Aucun développement externalisé à ce stade	—
A.8.31	Séparation des environnements de développement, de test et de production	Non	N/A	—	Pas de développement interne	—

ID	Contrôle	Applicable	Statut	Responsable	Preuve / Justification	Risque lié
A.8.32	Gestion du changement	Oui	Planifié	DSI	Procédure de gestion des changements IT à formaliser	R06, R08
A.8.33	Informations de test	Non	N/A	—	Pas d'environnement de test avec données réelles	—
A.8.34	Protection des systèmes d'information en cours d'audit	Oui	Planifié	DSI	Procédure d'audit non-intrusif à définir pour les audits externes	—

Taux A.8 : Implémenté : 1 (3%) / En cours : 17 (50%) / Planifié : 8 (24%) / N/A : 7 (21%) / Non : 1 (3%)

Synthèse globale

Taux de couverture par thème

Thème	Contrôles	Implémenté	En cours	Planifié	N/A	Non
A.5 Organisationnels	37	4 (11%)	18 (49%)	13 (35%)	1 (3%)	1 (3%)
A.6 Personnes	8	1 (13%)	4 (50%)	2 (25%)	0	1 (13%)
A.7 Physiques	14	3 (21%)	7 (50%)	3 (21%)	1 (7%)	0
A.8 Technologiques	34	1 (3%)	17 (50%)	8 (24%)	7 (21%)	1 (3%)
TOTAL	93	9 (10%)	46 (49%)	26 (28%)	9 (10%)	3 (3%)

Score de maturité global

Contrôles applicables : 93 - 9 (N/A) = 84
Implémentés : 9 -> 11%
En cours : 46 -> 55%
Planifiés : 26 -> 31%
Non conformes : 3 -> 4% <- GAPS ? traiter en priorité?

Lecture pour un CODIR : TechShop SAS a identifié 84 contrôles ISO 27001 applicables. 11% sont pleinement opérationnels, 55% sont en cours de déploiement, 31% sont planifiés. Les 3 non-conformités critiques sont : formation sécurité (A.6.3), MFA généralisé (A.8.5), et politique de sécurité formalisée (A.5.1). Ces 3 points seraient des **observations majeures** lors d'un audit de certification.

Top 5 des GAPS critiques

Priorité	Contrôle	Écart	Impact si non traité
1	A.6.3 — Formation sécurité	Aucune formation formelle	Non-conformité majeure audit + R10 élevé
2	A.8.5 — MFA	MFA sur 1 compte / 47	Compromission probable (R03 criticité 12)
3	A.5.1 — Politique sécurité	Document en cours	Fondation SMSI incomplète
4	A.8.7 — Anti-malware/EDR	EDR non déployé serveurs	R01 ransomware non couvert
5	A.5.29 — PRA/PCA	Non formalisé	RTO/RPO inconnus = risque majeur

Contrôles exclus (Non applicable) — Justifications formelles

ID	Contrôle	Justification d'exclusion
A.5.6	Relations groupes d'intérêt	PME sans obligation sectorielle de veille formalisée. Activité de veille informelle via CERT-FR.
A.7.12	Sécurité du câblage	Infrastructure principalement cloud/SaaS. Câblage local limité au réseau bureautique non critique.
A.8.4	Accès au code source	TechShop SAS n'a pas d'activité de développement logiciel interne.
A.8.25	Cycle de vie développement sécurisé	Idem A.8.4 — pas de développement interne.
A.8.27	Ingénierie systèmes sécurisés	Idem A.8.4.
A.8.28	Codage sécurisé	Idem A.8.4 — applicable uniquement aux éventuels développements sur mesure futurs.
A.8.29	Tests sécurité en développement	Idem A.8.4.
A.8.30	Externalisation du développement	Aucun développement externalisé actuellement.
A.8.31	Séparation environnements	Idem A.8.4 — pas d'environnement de dev/test interne.
A.8.33	Informations de test	Pas d'environnement de test avec données de production.

Note : Ces exclusions seront réévaluées si TechShop SAS lance un projet de développement interne ou de refonte technique majeure.

Document produit dans le cadre du SMSI TechShop SAS — Projet portfolio GRC Automation

Prochaine révision : Décembre 2026 (revue semestrielle) + Juin 2027 (revue annuelle)